

Diamond Model Analysis of the 2022 LastPass Data Breach

John Paul Rodriguez

1 INCIDENT DESCRIPTION

Between 8/8/2022 and 10/26/2022, LastPass's internal systems and critical user data was compromised in a two-phased attack. This attack impacted up to 1.6 million U.K. citizens with the global number believed to be much higher (Winder,2025). An adversary leveraged some of the compromised accounts to steal cryptocurrency totaling up to \$35M, according to TRM labs (a blockchain intelligence company) analysis of traced wallets. TRM labs analysis also indicated a pattern consistent with Russian hacker groups due to the use of multiple Russian Crypto Exchanges such as Cryptex and Audia6. The former of which has faced sanctions by the Office of Foreign Assets Control (OFAC) for providing financial services to cybercriminals (US Department of the Treasury, 2024).

The first phase of the attack took place on 8/8/2022. The adversary gained access to a LastPass developer's corporate laptop with access to the corporate environment. It is still unknown how the adversary got access to the developer's laptop; this initial access did not trigger any alerts. The adversary used this access to download source code from 14 of LastPass's code repositories and technical documentation. An encrypted version of an SSE-C key was discovered among this data, this key allowed access to production server backups. LastPass detected this malicious activity 4 days later and would publicly state that the breach was contained, and no customer data had been affected (Toubba, 2025).

The second phase of the attack occurred between 8/12/2022 and 10/26/2022. The adversary would leverage knowledge gained from the stolen source code to look for a second target. The adversary then targeted a senior DevOps engineers' personal laptop who they believed to have privileged access. The adversary discovered a vulnerable version of Plex Media Server running on the engineer's laptop. Due to this outdated version, the adversary exploited CVE-2020-5741, a high-severity remote code execution vulnerability, to gain remote access to the engineer's laptop. By exploiting this flaw, the adversary installed a keylogger on the laptop. With the keylogger, the adversary was able to acquire the AWS access key and decryption key for the SSE-C. These were used to gain access to the company's backup database. The adversary began exfiltrating a mix of unencrypted and encrypted data from this database. The unencrypted data included company names, end usernames, billing information, phone numbers,

IP addresses, vault metadata (used to see what websites customers log-in to) and some API keys. The encrypted data held the password vaults and master password that could access customer credentials (LastPass, 2026). The encrypted credentials related to cryptocurrency wallets remained a long-term target for the adversary, who would go on to successfully decrypt several of them over the following years (TRM, 2022).

With help from the incident response firm Mandiant, LastPass determined the scope of compromise and what data was stolen. On 12/22/2022, LastPass would publicly disclose the details of the attack.

2 APPLICATION OF THE DIAMOND MODEL

The diamond model approach will inspect multiple aspects of the attack as well as show the correlation between the features: Adversary, Victim, Infrastructure, and Capabilities. In Figure 1, each of the four core features is an “event”. The edges of the diamond represent relationships between these features.

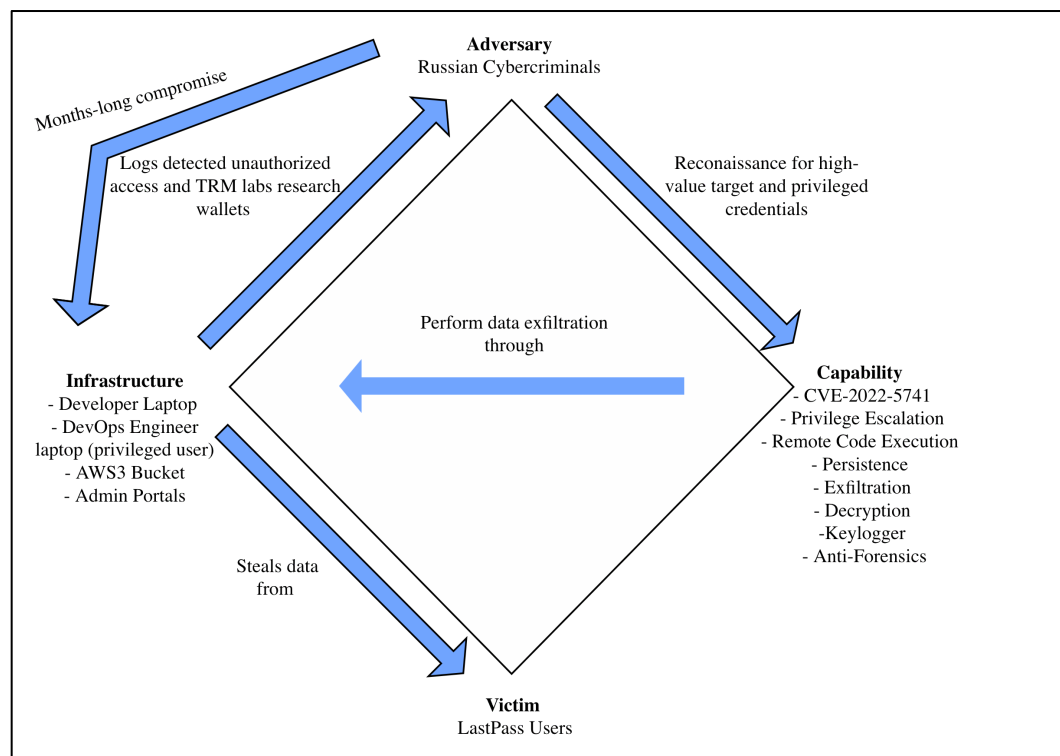


Figure 1: Diamond Model applied to the LastPass 2022 Data Breach

2.1 Adversary

Research done by TRM Labs 12/24/2025 provided evidence to suggest the LastPass breach was conducted by Russian cybercriminals. The Russian

cybercriminals targeted weak master passwords connected to crypto wallets to steal cryptocurrency. TRM labs would track the funds from these wallets through various mixers (used to obscure transaction trails) and ultimately through two high-risk Russian exchanges (TRM, 2025)(Coinbase, 2025). Cryptex, one of the Russian exchanges, was sanctioned by OFAC in 2024 due to the facilitation of ransomware laundering (U.S. Department of the Treasury, 2024). While it is likely that there are separate entities for “Adversary Operator” and “Adversary Customer” in this case, there is no concrete evidence proving whether this was done by one organized group or several different actors, for the purpose of this analysis I will group them as a single “Adversary”.

2.2 Capability

The adversaries in this attack demonstrated a wide range of capabilities that lead to the exploitation of the victims. This included an exploitation of CVE-2020-5741 to get remote access and persistence on a DevOps Engineers laptop. Once inside the LastPass environment the adversary was able to maintain persistence and get privileged escalation to the cloud environment where the victim data was held. Additionally, the adversary had the ability to process and exfiltrate large amounts of data to their own infrastructure while simultaneously using anti-forensic techniques to remain undetected. The decryption of the password vaults also indicates the adversaries have access to significant computing resources.

2.3 Victim

The LastPass users who had their data breached and cryptocurrency stolen are the “victims” in this model. While LastPass was breached and is facing multiple lawsuits, the goal of the breach was to steal individual customer (victim) data and cryptocurrency. LastPass, the developer, and the DevOps engineer are “victim assets” in this model due to their accounts and infrastructure being exploited as part of the attack.

2.4 Infrastructure

During the first phase of the attack, the adversary leveraged access to a developer's corporate laptop to get initial access to LastPass source code repositories. Using data from the source code, they determined the DevOps engineer to be a high-value target since he had access to admin portals and methods to decrypt the SSE-C keys. These keys gave adversaries access to the servers containing the victim's data. The adversary would maintain this access for 79 days in which the data was being siphoned to their own infrastructure. Utilizing this data, the adversary began stealing cryptocurrency from some customer wallets whose master passwords were decrypted. This would closely align with Type 2 infrastructure since LastPass infrastructure was unwittingly used by the adversary to exploit the victims (Caltagirone, S., Pendergast, A., & Betz, C., 2013).

2.5 Meta Features

2.5.1 Social Political — It is crucial to understand the business model of LastPass and the functionality of cryptocurrency to provide insight into the adversary / victim relationship. LastPass is a cloud-based password manager that provides customers with the infrastructure to keep their passwords in a secure place. Customers can store, generate, access, and delete passwords that they may use across their different accounts, most notably cryptocurrency wallets. To unlock a cryptocurrency wallet, the “owner” must provide a 12-24 word “seed phrase”. A common saying in the crypto community is “Not your keys, not your coins”, emphasizing that the possession of the seed phrase is equivalent to ownership of the wallet and its contents (Ledger, 2025)

Because many users stored these seed phrases in their LastPass vaults, the adversary targeted LastPass for financial gain due to the potential access to cryptocurrency. End users of LastPass provided the adversary with a “product” (seed-phrases for crypto wallets) while LastPass itself acted as the infrastructure leveraged by the adversary. By conducting a multi-stage attack on LastPass, the adversary escalated their privileges to find specific user data and proceeded to exfiltrate this data for 79 days. The adversaries' economic needs were not met with the initial breach of customer data, but with the continued decryption and draining of wallets spanning multiple years (TRM Labs, 2025). This aligns more closely with a “persistent adversary-victim relationship” rather than “smash and grab” as the victims, years later, are still being exploited.

2.5.2 Technology — Much like the “Social Political” section, it is important to have a deeper understanding of the technological structures LastPass utilized for its operations. The details of the initial compromise of the developer’s corporate laptop have remained unknown to the public; the significance lies in the architecture of LastPass that allowed the intrusion to expand. From this access, the adversary exfiltrated source code repositories and technical documentation. This gave them a deeper understanding of the structure of internal systems. Armed with this knowledge, the adversary found and exploited a second target.

It is also important to highlight the architectural design of database backups, and the handling of privileged access to these backups in this attack. The adversary targeted the DevOps personal laptop which essentially held “the keys to the kingdom”, as it provides access to AWS resources, decryption keys, and other critical secrets. This suggests that there was insufficient segmentation between employee endpoints and customer backup databases. A design centered around stricter roles, least privilege access, MFA hardware tokens, and separation between employee devices and production databases would have reduced the risk of compromise.

2.6 Activity Threads

Due to the phased nature of the attack, we can map activity threads for three victims. Two of the victims, the developer hacked in phase 1, and the DevOps engineer hacked in phase 2, are indirect victims. The third victim, the customers of LastPass, is the direct victim. There are three activity threads shown in figure 3, with Table 1 and Table 2 providing event and arc descriptions.

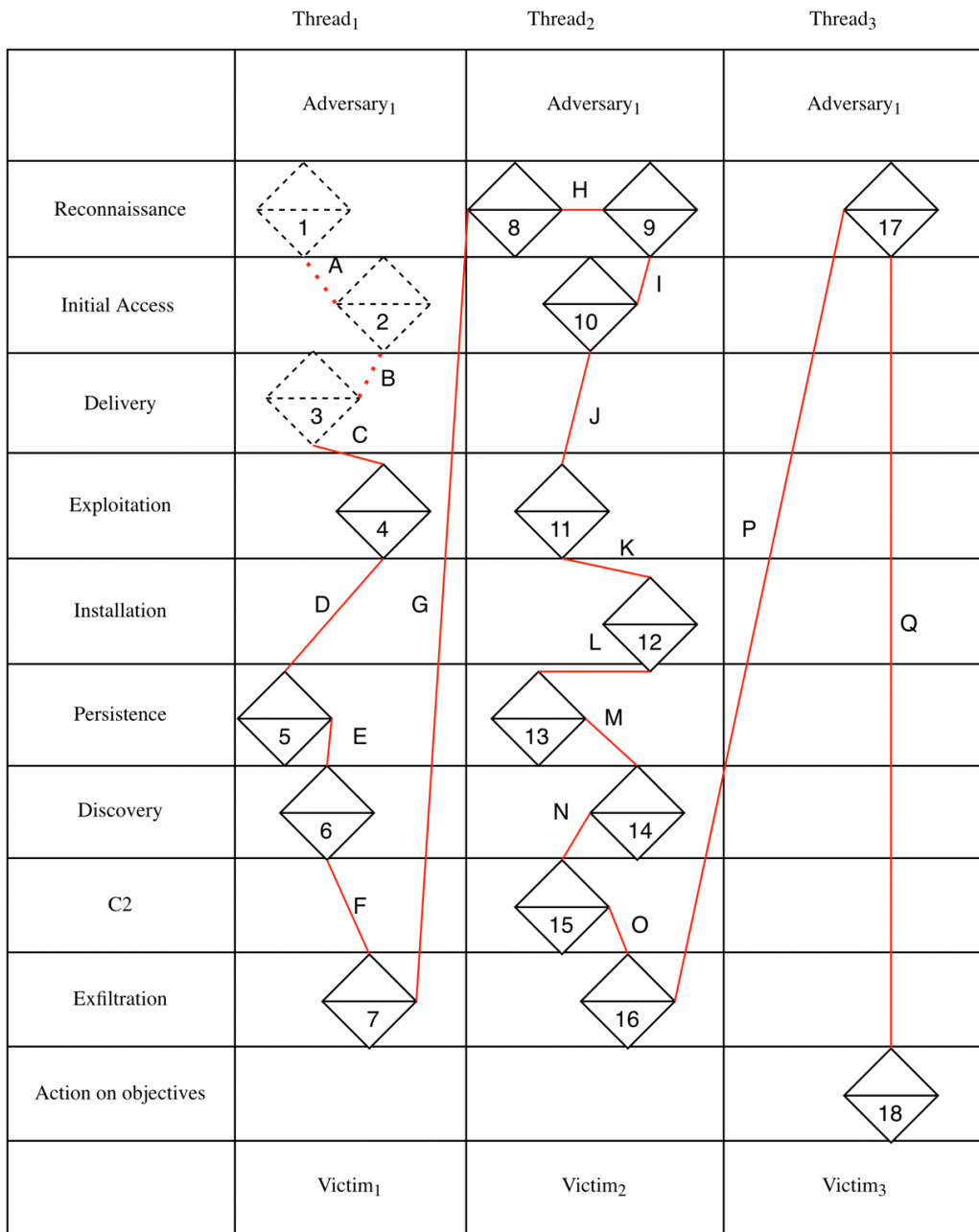


Figure 2: Activity Threads

Event	Hypothesis/Actual	Description
1	Hypothesis	Adversary conducts a web search for victim working at LastPass
2	Hypothesis	Adversary sends LastPass developer a phishing email
3	Hypothesis	Adversary gains access to LastPass developer's machine using an unknown exploit
4	Actual	Exploit allows attacker to look for codebase
5	Actual	Adversary maintains persistence in the system
6	Actual	Adversary finds source code and proprietary technical information
7	Actual	Adversary exfiltrates this source code and information
8	Actual	Adversary uses source code to identify high value target
9	Actual	High value target is identified as 1 of 4 DevOps Engineer's with access to customer data backups
10	Actual	Adversary gains initial access to DevOps Engineer's personal laptop
11	Actual	Exploitation of CVE-2020-5741 allows adversary to have Remote Code Execution on the laptop
12	Actual	Adversary uses Remote Code Execution to install keylogger on laptop
13	Actual	Adversary maintains persistence on laptop
14	Actual	Keylogger allows adversary to gain access to backup customer database
15	Actual	Adversary uses VPN to hide their own infrastructure and remain undetected
16	Actual	Adversary begins exfiltration of backup database and other information
17	Actual	Stolen vault metadata allows the adversary to target encrypted keys connected to crypto wallets
18	Actual	Adversary would decrypt these keys and siphon cryptocurrency from wallets

Table 1: Activity Thread Descriptions for Figure 2

Arc	Confidence	And/Or	Hypothesis/Actual	Provides
A	Low	Or	Hypothesis	Spear-phishing target
B	Low	Or	Hypothesis	Phish gives vector for exploitation
C	Medium	And	Hypothesis	Gives access to codebase
D	Medium	And	Actual	[None]
E	High	And	Actual	4 days with access to codebase
F	High	And	Actual	[None]
G	High	And	Actual	Opportunity to find new target
H	High	And	Actual	[None]
I	High	And	Actual	Laptop to target
J	High	And	Actual	Vulnerable plex software grants exploit opportunity
K	High	And	Actual	Plex RCE gives ability to install keylogger
L	High	And	Actual	[None]
M	High	And	Actual	Keylogger gets privileged credentials
N	High	And	Actual	Credentials give access to backup customer database
O	High	And	Actual	Exfiltration of data
P	High	And	Actual	List of targets to steal crypto from
Q	High	And	Actual	Access to contents of crypto wallets

Table 2: Activity Thread Arc Descriptions for Figure 2

3 POLICY ASSESMENT

While it is impossible for a company to implement security controls where they will never be breached, there are steps that can be taken to ensure these breaches are rare and less impactful. The LastPass 2022 breach occurred due to negligence at the organizational level of the company. Phase 1 of the attack could have been prevented by implementing stronger endpoint monitoring. By the time of phase 2, LastPass had the opportunity to fix infrastructure-related vulnerabilities and failed to do so. The compromise of the DevOps engineer's laptop highlights the importance of least-privilege access, endpoint protection, hardware-backed MFA, and BYOD policies to ensure personal devices meet security standards prior to access to sensitive systems.

There was no operational reason for a single personal laptop to have access to an AWS S3 bucket containing all customer data. If such access was necessary, the organization should have used stronger authentication controls such as hardware-backed MFA, which would have prevented compromise in the event of a network-based attack. These measures would have prevented the adversary from authenticating even after gaining access to the endpoint. A least-privilege approach for developer accounts using rotating keys would have prevented the persistence of the adversary in the database. Further, detection of the second phase of the attack was first flagged by AWS GuardDuty 79 days later, demonstrating that internal monitoring and alerting were also inadequate.

Due to the inevitable nature of cyberattacks on high priority targets such as LastPass, it is important for these companies to protect themselves on the legal front as well. By purchasing cyber insurance, LastPass ensures coverage to mitigate financial exposure due to data breaches. This recommendation is particularly relevant because LastPass recently agreed to pay \$24.45 million for customers affected in the U.S. [6] and is being fined by the Information Commissioners Office (ICO) of the U.K. for £1.2 million (ICO, 2025). LastPass will also be reimbursing up to \$900,000 per customer who fell victim to the cryptocurrency wallet thefts (LastPasssettlement.com, 2026). Cyber-insurance would not directly reduce the likelihood of a data breach but would provide stronger cybersecurity measures through regular auditing and risk assessments.

While the breach had global consequences, national and transnational policies would not have prevented this attack from occurring. The sanctions imposed on the Russian-crypto exchange "Cryptex" had little to no effect on the outcome. The post-mortem analysis of the breach demonstrates that changes at the organizational level would have been most effective in preventing this attack.

4 CONCLUSION

The LastPass 2022 breach demonstrates how a localized compromise of a developer's corporate laptop can escalate into a large-scale incident affecting

both LastPass and its customers. Applying the diamond model and activity threads allowed for a clear mapping of the adversary, their capabilities, the victim, and how LastPass infrastructure was leveraged to access sensitive data. The attack was largely due to the lack of policy enforcement surrounding overprivileged endpoints, authentication controls, BYOD policies, and endpoint monitoring. This case shows the importance of understanding the adversary-victim and technology relationships to build resilient systems and proper security policies to reduce the impact of similar future breaches.

5 REFERENCES

- [1] Grossman, N. (2026, March 24). *The LastPass breach: how convenience became a compliance failure* - VinciWorks. VinciWorks.
<https://vinciworks.com/blog/the-lastpass-breach-how-convenience-became-a-compliance-failure/>
- [2] CyberGeeK. (2025, December 16). *Understanding the LastPass Data Breach: What Happened, What Was Exposed, and Why It Still Matters*. Medium.
<https://medium.com/@cybergeek089/understanding-the-lastpass-data-breach-what-happened-what-was-exposed-and-why-it-still-matters-6f0d91e37927>
- [3] Amishav, J. (2026, January 15). *LastPass Data Breach Case Study: Causes and Aftermath*. Breachsense.com; Breachsense.
<https://www.breachsense.com/blog/lastpass-data-breach-case-study/>

- [4] News, T. H. (2025, December 25). *LastPass 2022 Breach Led to Years-Long Cryptocurrency Thefts, TRM Labs Finds*. The Hacker News. <https://thehackernews.com/2025/12/lastpass-2022-breach-led-to-years-long.html>
- [5] Kost, E. (2023, August 3). *The LastPass Vulnerability and the Future of Password Security* | UpGuard. [Www.upguard.com. https://www.upguard.com/blog/lastpass-vulnerability-and-future-of-password-security](https://www.upguard.com/blog/lastpass-vulnerability-and-future-of-password-security)
- [6] <https://www.facebook.com/allaboutlawyer>. (2026, March 28). *LastPass \$24.45M Settlement: Claim Up To \$900,000 By 2 July*. All about Lawyer. <https://allaboutlawyer.com/lastpass-24450000-data-breach-settlement/>
- [7] Jones, C. (2025, December 11). *LastPass hammered with £1.2M fine for 2022 breach fiasco*. Theregister.com; The Register. https://www.theregister.com/2025/12/11/lastpass_ico_fine/
- [8] Karim Toubba. (2022, December 22). *Security Incident December 2022 Update - LastPass - The LastPass Blog*. Lastpass.com. <https://blog.lastpass.com/posts/notice-of-recent-security-incident>
- [9] TRM Traces Stolen Crypto from 2022 LastPass Breach — On-chain Indicators Suggest Russian Cybercriminal Involvement | TRM Blog. (2022). Trmlabs.com. <https://www.trmlabs.com/resources/blog/trm-traces-stolen-crypto-from-2022-lastpass-breach-on-chain-indicators-suggest-russian-cybercriminal-involvement>
- [10] *What is a Bitcoin mixer?* (2024). @Coinbase; Coinbase. <https://www.coinbase.com/learn/your-crypto/what-is-a-bitcoin-mixer>
- [11] Gentles, J., Fields, M., Goodman, G., & Bhunia, S. (n.d.). *Breaking the Vault: A Case Study of the 2022 LastPass Data Breach*. <https://arxiv.org/pdf/2502.04287>
- [12] Caltagirone, S., Pendergast, A., & Betz, C. (2013). *The Diamond Model of Intrusion Analysis*. <https://www.activeresponse.org/wp-content/uploads/2013/07/diamond.pdf>
- [13] Winder, D. (2025, December 14). *LastPass Data Breach — 1.6 Million Users Exposed By Security Failure*. Forbes. <https://www.forbes.com/sites/daveywinder/2025/12/14/lastpass-data-breach---insufficient-security-exposed-16-million-users/>
- [14] *Treasury Sanctions Cryptocurrency Exchange and Network Enabling Sanctions Evasion and Cyber Criminals*. (2025, August 14). U.S. Department of the Treasury. <https://home.treasury.gov/news/press-releases/sb0225>
- [15] *Treasury Takes Coordinated Actions Against Illicit Russian Virtual Currency Exchanges and Cybercrime Facilitator*. (2024, September 26). U.S. Department of the Treasury. <https://home.treasury.gov/news/press-releases/jy2616>
- [16] *What is LastPass? Secure Password Management Guide*. (2025, September 30). Cybers Guards. <https://cybersguards.com/what-is-lastpass/>

- [17] *What Is a Seed Phrase? (Secret Recovery Phrase)*. (2024, September 10). Cryptonews. <https://cryptonews.com/academy/seed-phrase/>
- [18] *Not Your Keys, Not Your Coins: Why It Matters*. (n.d.). Ledger. <https://www.ledger.com/academy/not-your-keys-not-your-coins-why-it-matters>
- [19] *Customer*. (2026). Lastpass.com. https://support.lastpass.com/s/document-item?language=en_US&LANG=enus&bundleId=lastpass&topicId=LastPass%2Fincident-2-details.html
- [20] *Password manager provider fined £1.2m by ICO for data breach affecting up to 1.6 million people in the UK*. (2025, December 11). Ico.org.uk; ICO. <https://ico.org.uk/about-the-ico/media-centre/news-and-blogs/2025/12/password-manager-provider-fined/>
- [21] *LastPass Data Security Incident Litigation - Home*. (2022). Lastpasssettlement.com. <https://www.lastpasssettlement.com/>